

AP12 · Auditoría – Ayuntamiento de Bollullos

Alumno: Xavier Margalef

Metodología: MAGERIT v3 · ENS

Fecha: 14/07/2026

Actividad: [AP 12] Auditoría - Ayuntamiento Bollullos



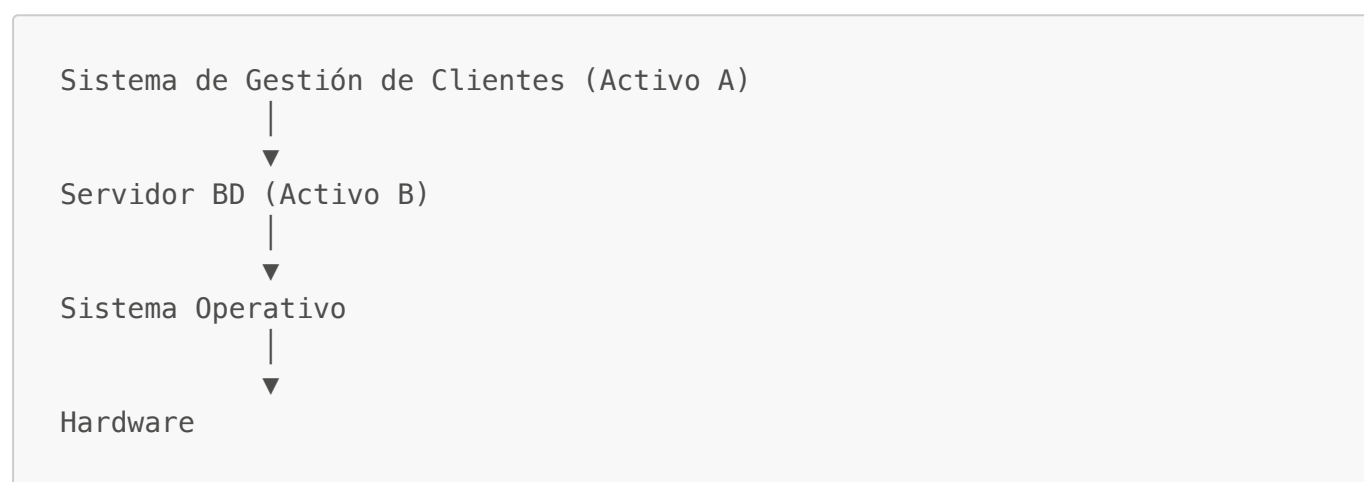
1. Valor Propio / Acumulado del Activo A

El Activo A es el activo esencial que depende del Activo B que es el sistema de soporte, por lo que el activo A no acumula valor heredado del B.

$v_{\text{activo}} = 3, 4, 2, 4, 3$

El Sistema de Gestión depende del Servidor para funcionar. Por eso el Servidor hereda el valor del Sistema de Gestión, no al revés.

El valor de los activos esenciales se propaga hacia los activos de soporte, porque son estos los que deben protegerse para mantener operativo el negocio.



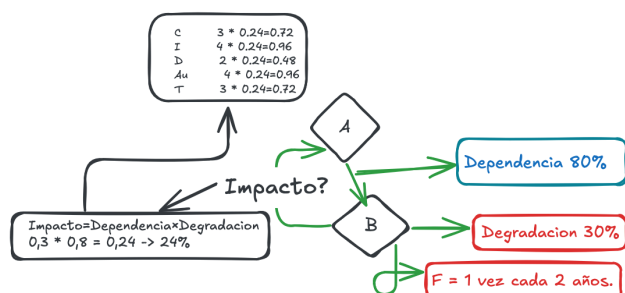
En conclusión, **Valor Propio = Valor Acumulado**.

El valor propio del Activo A en dimensiones del [Esquema Nacional de Seguridad \(ENS\)](#) por el método [MAGERIT v3](#) es:

- **C** (Confidencialidad) = 3
- **I** (Integridad) = 4 (*Activo Crítico*)
- **D** (Disponibilidad) = 2
- **Au** (Autenticidad) = 4 (*Activo Crítico*)
- **T** (Trazabilidad) = 3

En ese caso, **40.000 €** simplemente sirve para calcular las pérdidas económicas en las dos últimas secciones.

2. El Impacto Repercutido sobre el negocio (Activo A) por la caída del servidor (Activo B)



$$Impacto = Dependencia \times Degradación$$

- **Dependencia:** 80% = 0.8
- **Degradación:** 30% = 0.3

Entonces:

$$0.8 \times 0.3 = 24\%$$

Ese **24%** afecta a todas las dimensiones. Por tanto:

Dimensión	Operación	Impacto Repercutido
C	3×0.24	0.72
I	4×0.24	0.96
D	2×0.24	0.48
Au	4×0.24	0.96
T	3×0.24	0.72

Interpretación Técnico: Estos valores significan cuánto daño recibe cada propiedad de seguridad del Activo A. Por ejemplo, **0.96** sobre 4. Como la dimensión de la *Integridad* se considera un activo crítico, a causa del impacto por caída del activo por la degradación en base a la dependencia, pues su daño resultante es mayor a la de la *Disponibilidad* (0.48). Se han perdido puntos de valor nominales en las dimensiones del activo, traduciéndose en una pérdida directa de valor.

3. El Riesgo Inicial del Activo A

En la metodología de gestión de riesgos **MAGERIT**, el cálculo base se estructura como:

$$Riesgo = Impacto \times Frecuencia$$

- **Frecuencia:** 1 vez cada 2 años $F = 0.5$

Por tanto:

Dimensión	Operación (Impacto × Frecuencia)	Riesgo Inicial
C	0.72×0.5	0.36
I	0.96×0.5	0.48
D	0.48×0.5	0.24
Au	0.96×0.5	0.48
T	0.72×0.5	0.36

Conceptos Clave de la Cadena de Riesgo:

- **Valor:** ¿Qué tan importante es el activo? Ej.: *Integridad = 4*.
- **Impacto:** Si el ataque ocurre, ¿cuánto valor pierdo? Ej.: *0.96 puntos*.
- **Riesgo:** Como el ataque no ocurre siempre, ¿cuál es la pérdida esperada teniendo en cuenta su frecuencia? Ej.: $0.96 \times 0.5 = 0.48$.

4. El Riesgo Residual si aplicamos un WAF con una eficacia del 60%

El **WAF** ([Web Application Firewall](#)) entraría dentro de las **salvaguardas preventivas** porque actúa antes de que suceda alguna explotación de vulnerabilidad, reduciendo el vector de ataque y en total el riesgo.

Definición de Riesgo Residual: Es el riesgo que permanece después de que se hayan implementado controles o medidas de mitigación para reducir la probabilidad o el impacto de un evento adverso. Representa la parte del riesgo que no puede ser eliminada completamente y que la organización debe aceptar, gestionar o transferir según las directrices [ISO/IEC 27005](#).

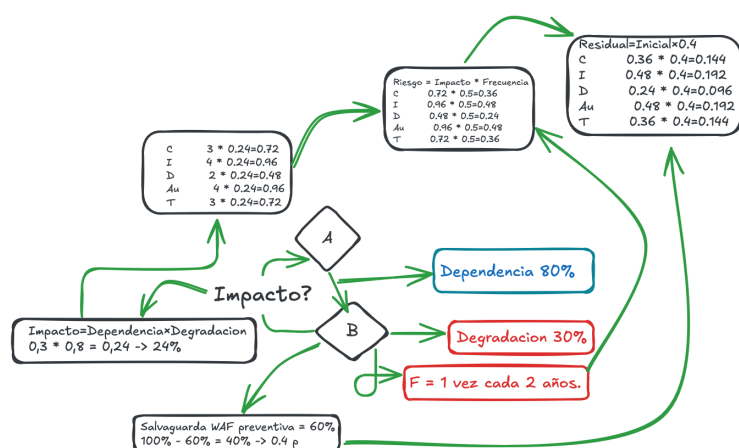
Seguimos con la lógica de que cada dimensión representa una sección dentro como activo del valor total, y debe medirse por separado porque según qué salvaguardas o según el valor del activo pues es variante.

El WAF reduce el riesgo un 60%, por lo que **queda el 40% del riesgo remanente**.

$$Residual = Inicial \times 0.4$$

Entonces:

Dimensión	Operación (Riesgo Inicial × 0.4)	Riesgo Residual
C	0.36×0.4	0.144
I	0.48×0.4	0.192
D	0.24×0.4	0.096
Au	0.48×0.4	0.192
T	0.36×0.4	0.144



5. El dinero exacto que ha perdido el Ayuntamiento en el ataque (A d. S)

La pérdida real del ataque es el porcentaje de impacto sobre el negocio.

El **SLE** ([Single Loss Expectancy](#)) significa pérdida esperada por un único incidente. El SLE calcula cuánto dinero perdería la organización si una amenaza concreta afectara a un activo una sola vez.

- **Impacto:** 24%
- **Activo:** 40.000 €

$$SLE = Valor \times Factor de Exposición(Impacto)$$

$$SLE = 40.000 \times 0.24 = \mathbf{9.600 \text{ €}}$$

6. El dinero que perderá en un año (A d. S)

Aquí entra en juego no solo una ocurrencia sino el ratio. El **ALE** ([Annualized Loss Expectancy](#)) representa la Pérdida Anual Esperada y calcula cuánto dinero espera perder una organización en un año debido a un riesgo concreto.

$$ALE = SLE \times ARO$$

El **ARO** (*Annualized Rate of Occurrence*) significa la tasa anual de ocurrencia (en este caso, nuestra frecuencia de 0.5).

$$ALE = 9.600 \times 0.5 = \mathbf{4.800 \text{ €/año}}$$

(Nota: **A d. S** = Antes de Salvaguardas, lo cual significa que los puntos 5 y 6 se calculan sin tener en cuenta el WAF).

7. Calcula si tiene sentido aplicar esta medida

La licencia de Cloudflare Business más las horas de mantenimiento del técnico es de **1.200 € anuales**. Básicamente tenemos que hacer los cálculos con la situación inicial, antes de aplicar cualquier salvaguarda para comparar esa situación inicial con la situación después del WAF para decidir si la inversión merece la pena.

- **Sin protección (Pérdida anual esperada):** 4.800 €
- **Con WAF (Reduce el riesgo un 60%):** $4.800 \times 0.4 = 1.920$ €
- **Coste del WAF:** Si le metemos el coste del WAF que son 1.200 €, nos deja en **3.120 € totales**.

Comparativa de Gastos Anuales

- **Sin WAF:** 4.800 €/año
- **Con WAF:** 3.120 €/año (1.920 € de riesgo residual + 1.200 € de coste)

$$\text{Ahorro Esperado} = 4.800 - 3.120 = \mathbf{1.680 \text{ €/año}}$$

Por tanto: **Sí, económicamente compensa implantar la medida**, ya que el coste total anual (3.120 €) es inferior a la pérdida anual esperada sin protección (4.800 €), generando un ahorro esperado de 1.680 € al año.

Cálculo del ROSI (Return on Security Investment)

Para validar formalmente la rentabilidad bajo estándares internacionales de auditoría, aplicamos la métrica del **ROSI**:

$$\text{ROSI} = \text{Riesgo Mitigado} - \text{Coste de la Solución} / \text{Coste}$$

$$\text{ROSI} = 2.880 - 1.200 / 1.200 = \mathbf{140\%}$$

Interpretación Financiera: Un ROSI positivo del **140%** indica que la inversión es altamente rentable, ya que el valor económico del riesgo que mitiga supera con creces el coste anual de la solución tecnológica.

Resumen Final de Control

Apartado / Pregunta	¿Con WAF?	Expresión / Fórmula	Resultado Neto
Valor Propio/Acumulado	-	Escala ENS / MAGERIT	C3 I4 D2 Au4 T3
Impacto Repercutido	-	<i>Dependencia</i> $\times$ <i>Degradación</i>	24 %
Riesgo Inicial	✗ No	<i>Impacto</i> $\times$ <i>Frecuencia</i>	C0.36 I0.48 D0.24 Au0.48 T0.36
Riesgo Residual	✓ Sí	<i>Inicial</i> $\times$ 0.4	C0.144 I0.192 D0.096 Au0.192 T0.144
5. Dinero Perdido (A d. S.)	✗ No	$SLE = 40.000 \times 0.24$	9.600 €
6. Dinero Perdido al Año (A d. S.)	✗ No	$ALE = 9.600 \times 0.5$	4.800 €/año
7. ¿Compensa el WAF?	✓ Sí	<i>Coste</i> <i>Efectivo</i> <i>Total</i>	Sí, ahorro de 1.680 €/año (140% ROSI)